



网络空间安全技术

杭州电子科技大学

网络空间安全学院&浙江保密学院

王秋华

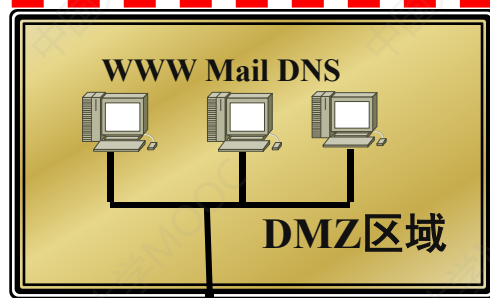
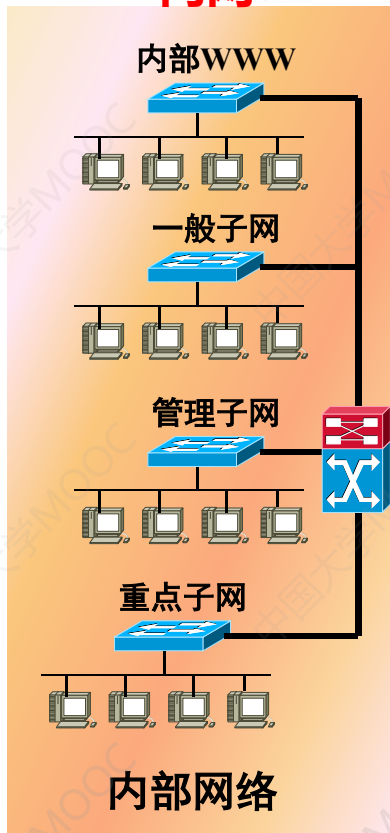
A grayscale background image of a city skyline, likely New York City, with numerous skyscrapers and buildings. The image is slightly faded and serves as a backdrop for the chapter title.

02 内容

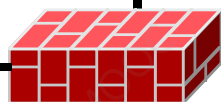
第2章 局域网攻击及防御技术

主要内容

内网



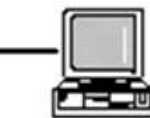
DMZ区域



边界路由器



外网

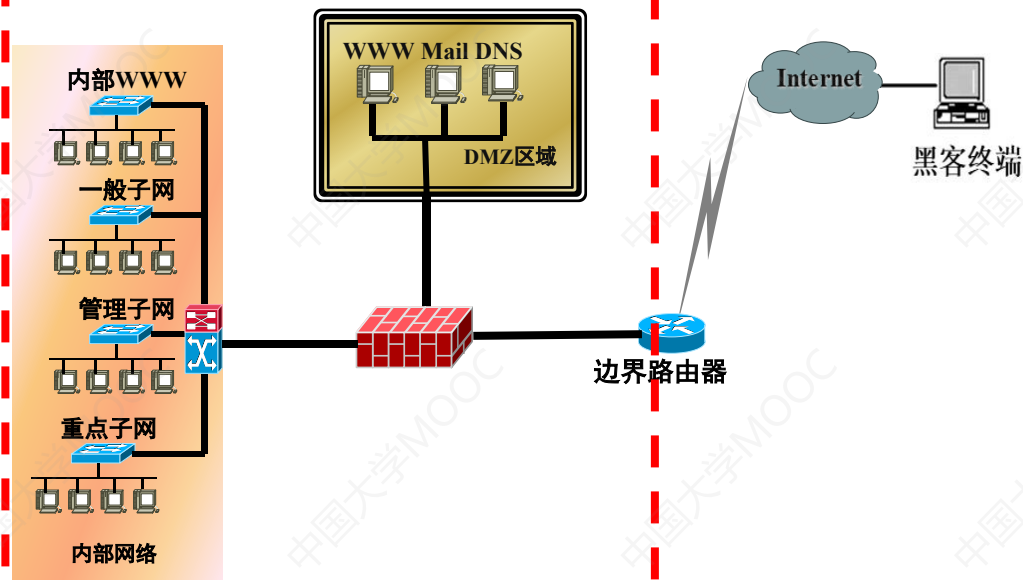


黑客终端

局域网安全

主要内容

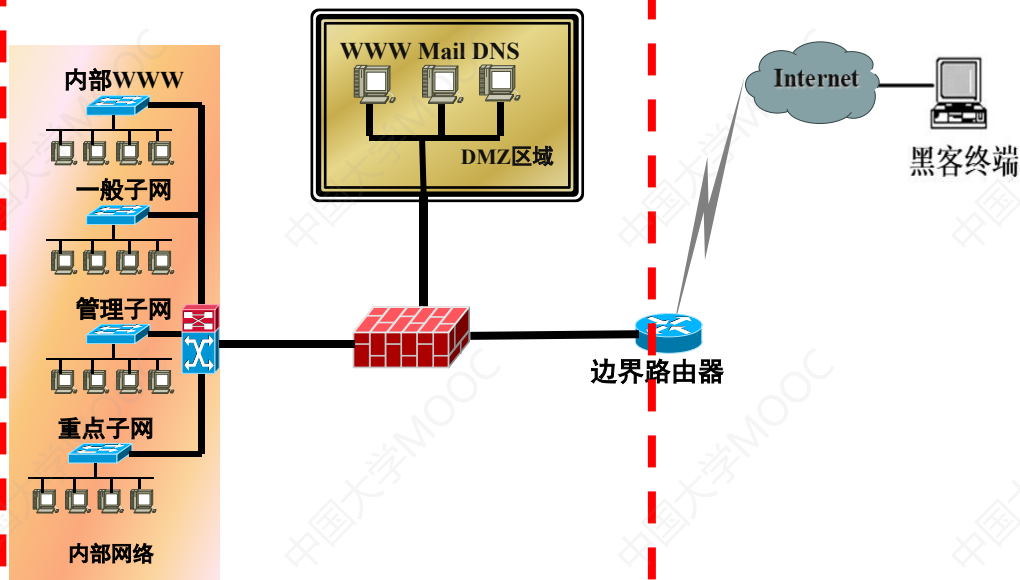
内网



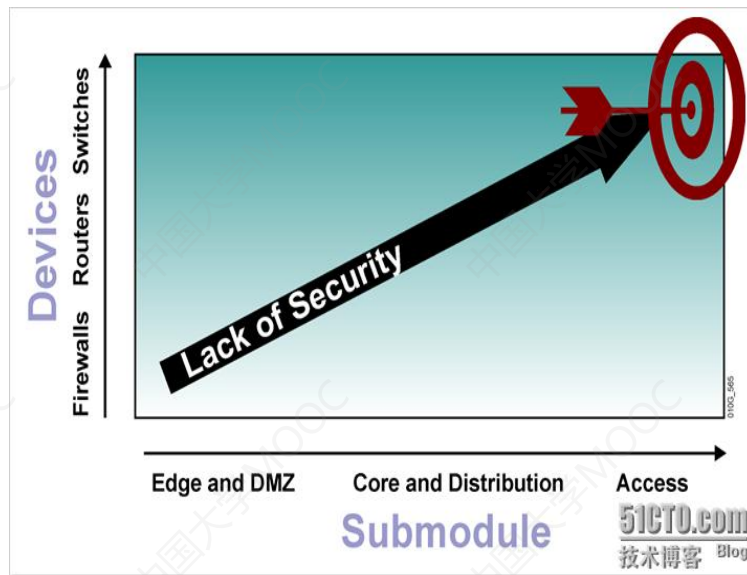
内网中最主要的接入设备？

主要内容

内网



内网中最主要的接入设备?



离接入层越近风险越大，所以问题主要集中在接入层。
交换机到底存在哪些安全呢？

主要内容



2.1 网络攻击的定义和分类

2.2 窃听攻击的原理及防御

2.3 截获攻击的原理及防御

2.4 欺骗攻击的原理及防御

2.1 网络攻击的定义和分类

1. 网络攻击的定义



网络攻击：是指**利用**网络中存在的**漏洞和安全缺陷**对网络中的**硬件、软件及信息**进行的攻击，其**目的**是破坏网络中信息的**保密性、完整性、可用性、可控制性和不可抵赖性**，**削弱、甚至瘫痪**网络的服务功能。

2.1 网络攻击的定义和分类

2. 网络攻击的分类



□ 主动攻击

主动攻击：是指会**改变**网络中的信息、状态和信息流模式的攻击行为。主动攻击可以**破坏**信息的保密性、完整性和可用性等。



□ 被动攻击

被动攻击：是指**不会**对经过网络传输的信息、网络状态和网络信息流模式产生影响的攻击行为。被动攻击一般只**破坏**信息的保密性。



2.1 网络攻击的定义和分类

2. 网络攻击的分类

□ 被动攻击类型

- 嗅探信息;
- 非法访问;
- 数据流分析。

□ 主动攻击类型

- 篡改信息;
- 欺骗攻击;
- 拒绝服务攻击;
- 重放攻击。

举例



2.1 网络攻击的定义和分类

被动攻击——窃听、流量分析

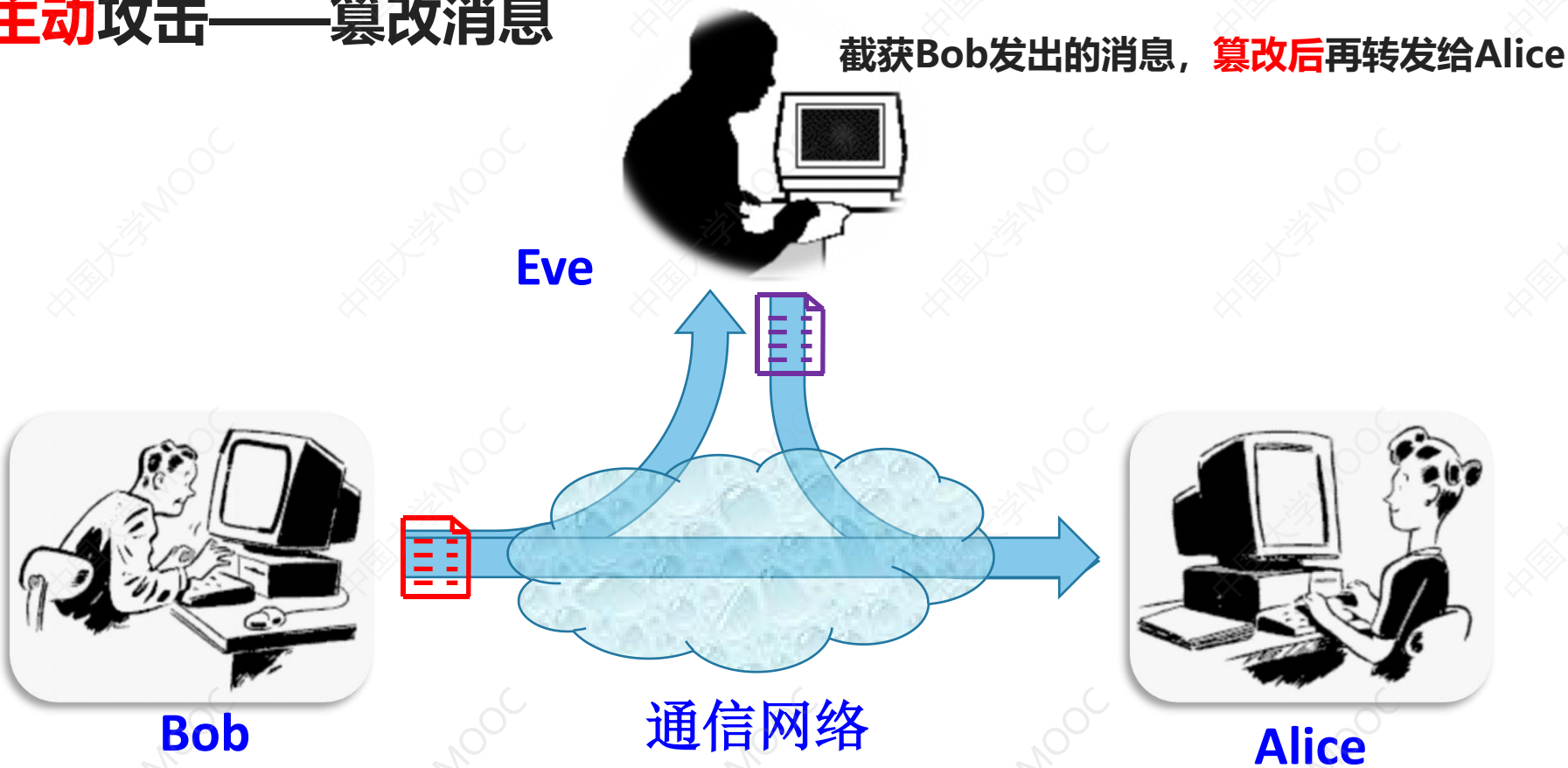
窃听消息，分析消息模式



□ 在被动攻击中，攻击者只是观察和分析网络中传输的数据，而不干扰信息流。

2.1 网络攻击的定义和分类

主动攻击——篡改消息

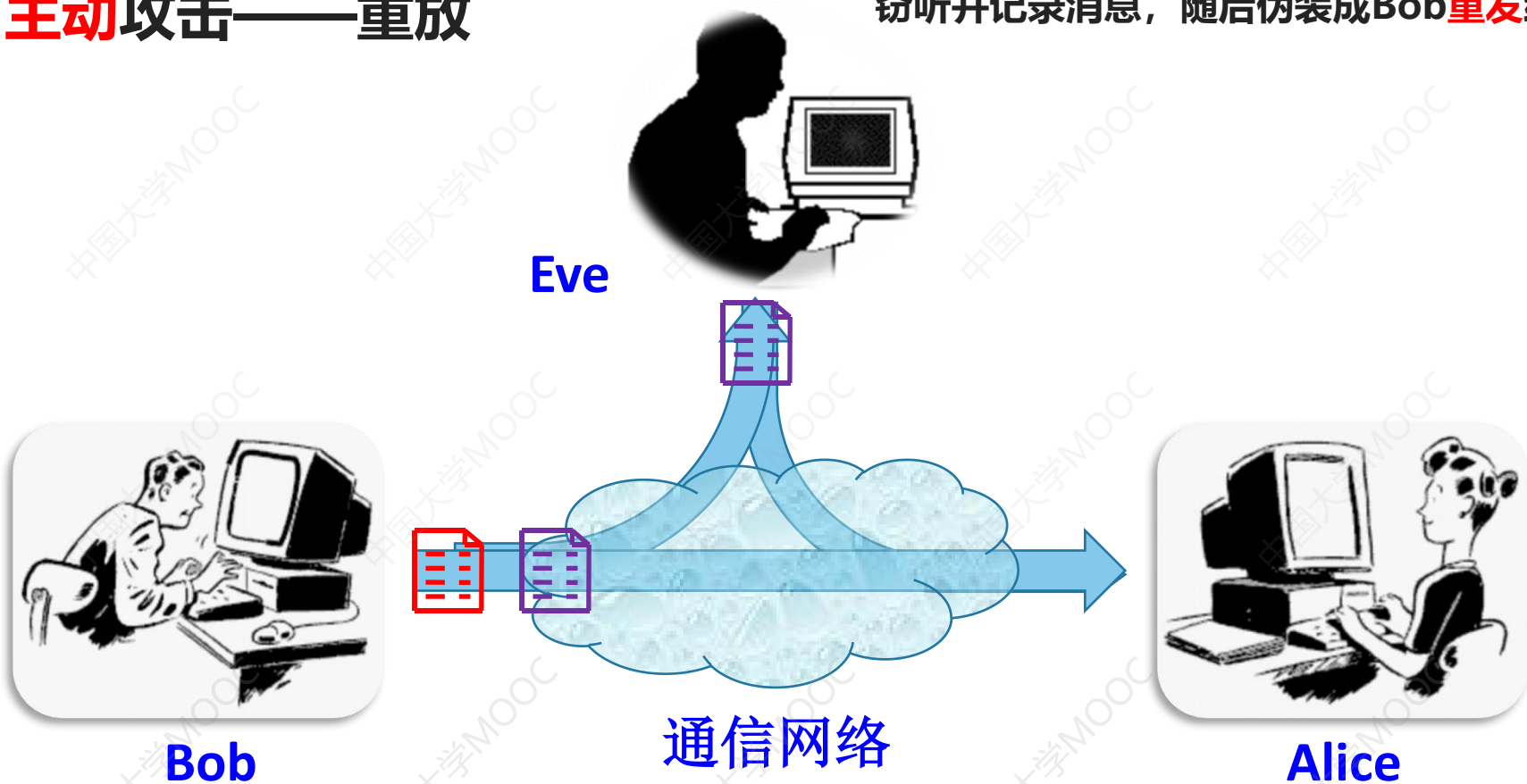


□ 主动攻击是指攻击者对某个连接中通过的数据进行各种处理。

2.1 网络攻击的定义和分类

主动攻击——重放

窃听并记录消息，随后伪装成Bob重发给Alice



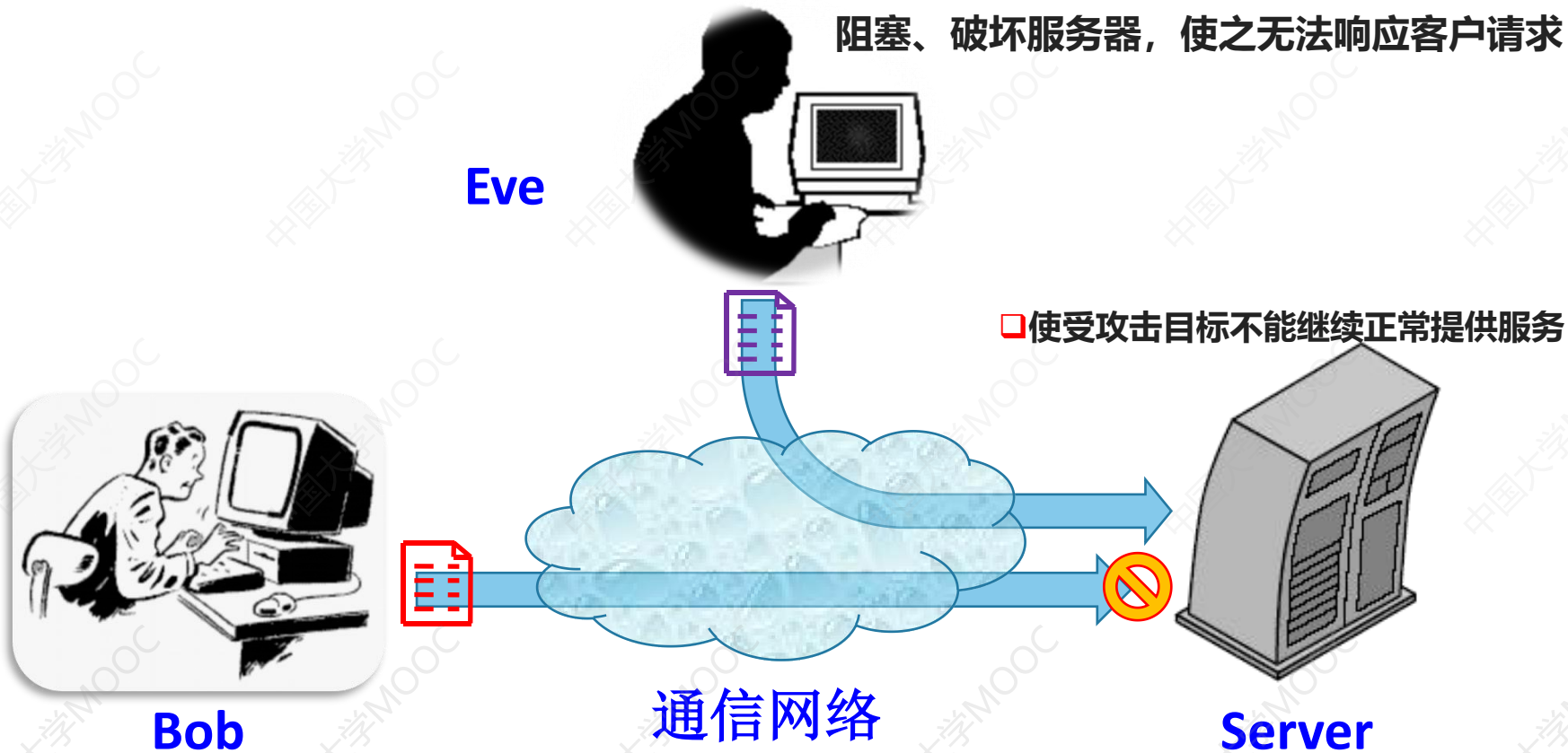
2.1 网络攻击的定义和分类

主动攻击——伪装



2.1 网络攻击的定义和分类

主动攻击——拒绝服务



主要内容



2.1 网络攻击的定义和分类

2.2 窃听攻击的原理及防御

2.3 截获攻击的原理及防御

2.4 欺骗攻击的原理及防御

2.2.1 窃听攻击的原理及后果

1. 窃听攻击原理

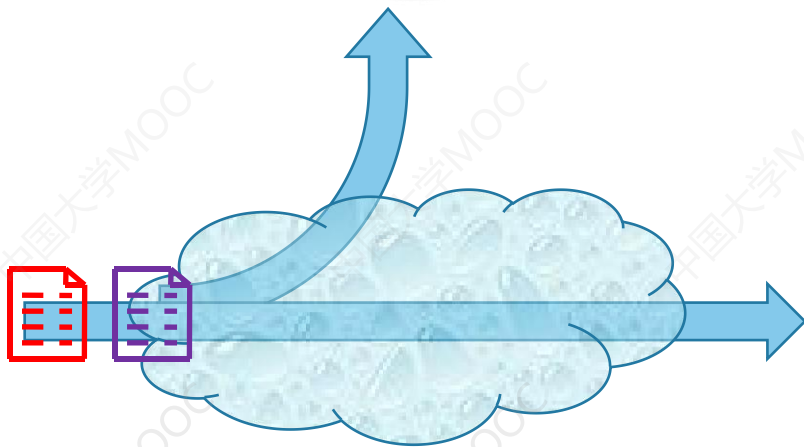
复制信息:

- 不影响信息的正常传输
- 对网络和主机都**透明**

黑客终端



终端A



通信网络



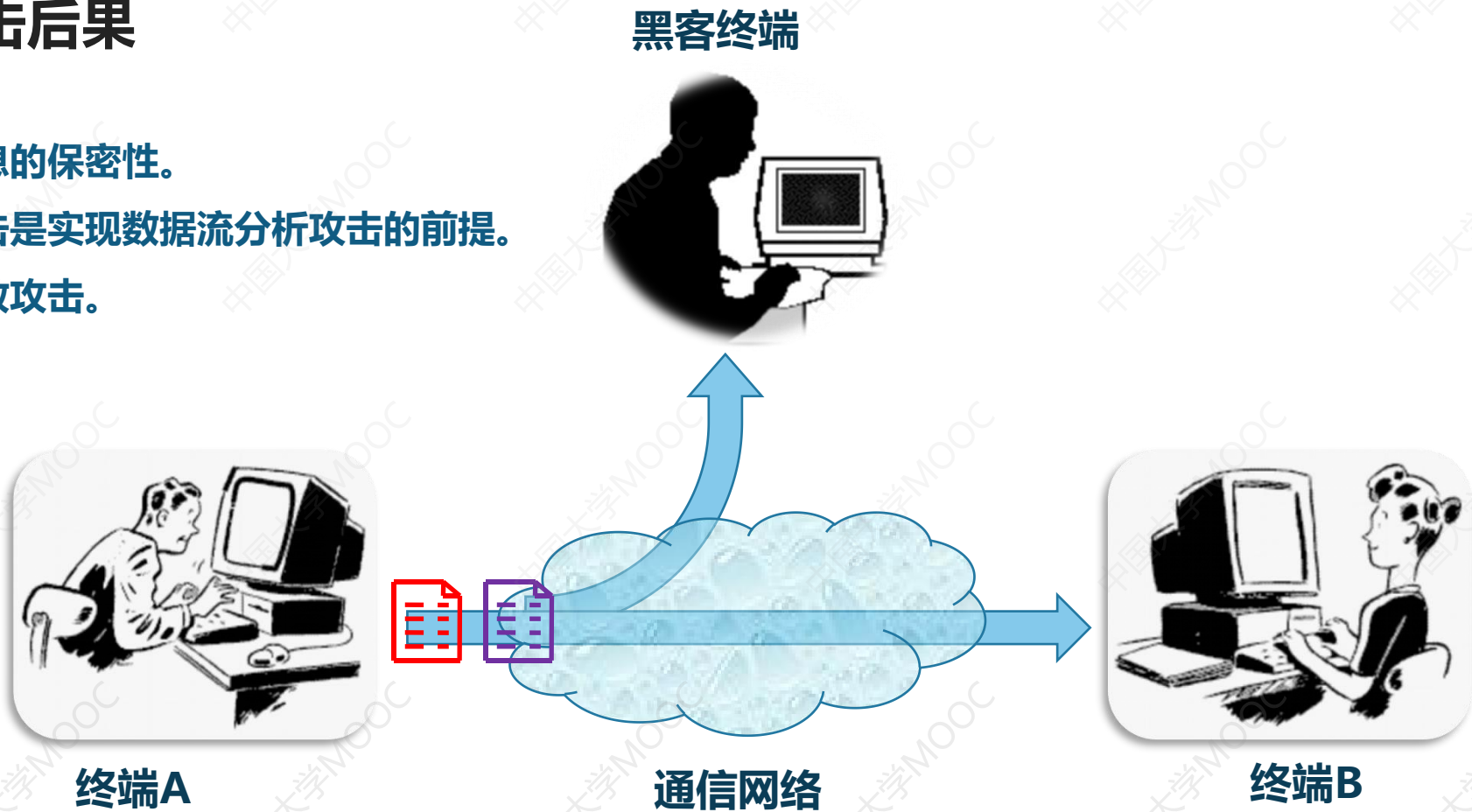
终端B

终端A向终端B传输信息过程中，信息不仅沿着终端A至终端B的传输路径传输，还沿着终端A至黑客终端的传输路径传输，且终端A至黑客终端的传输路径对终端A和终端B都是**透明**的。

2.2.1 窃听攻击的原理及后果

2. 窃听攻击后果

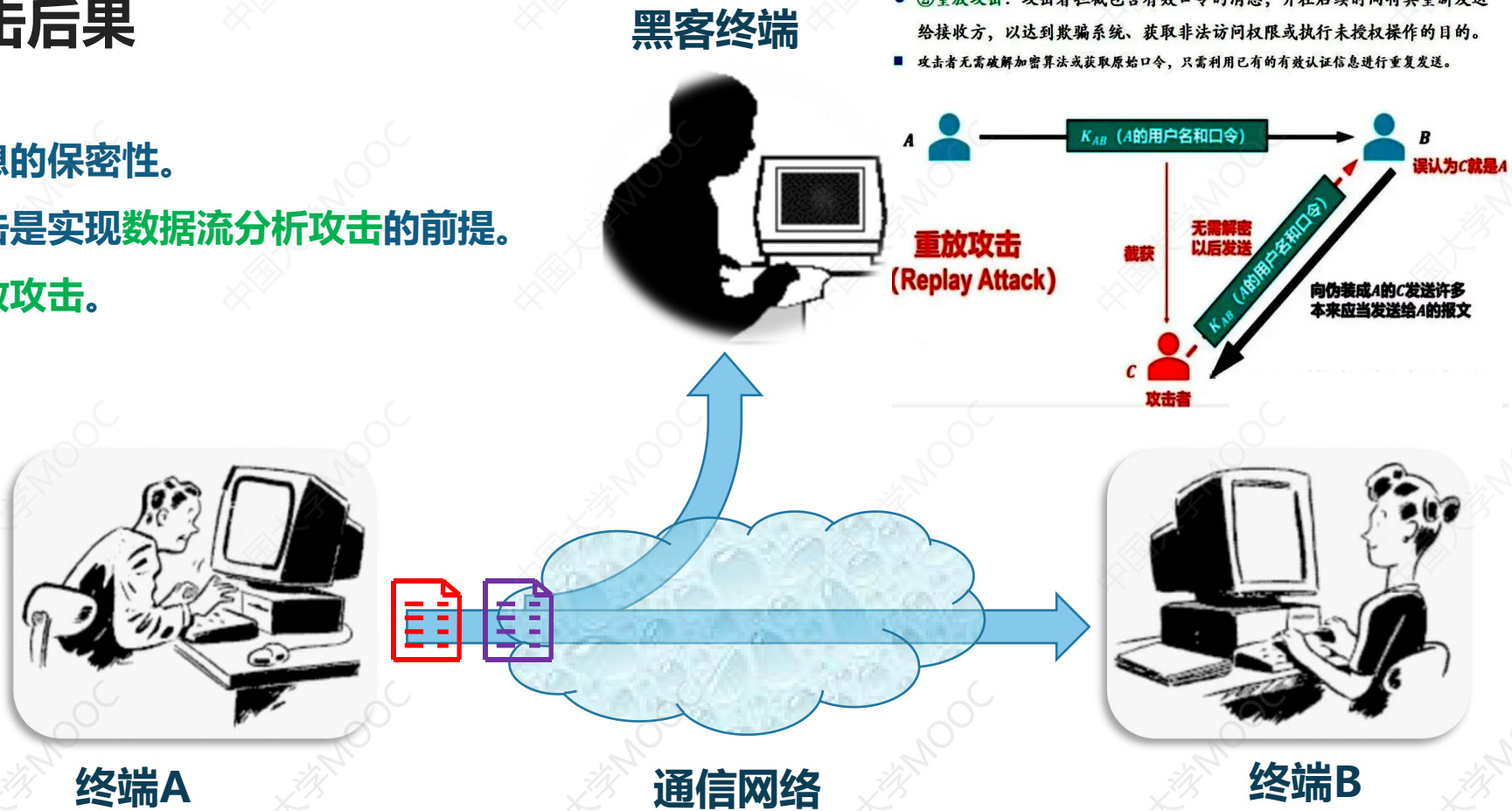
- 一是破坏信息的保密性。
- 二是嗅探攻击是实现数据流分析攻击的前提。
- 三是实施重放攻击。



2.2.1 窃听攻击的原理及后果

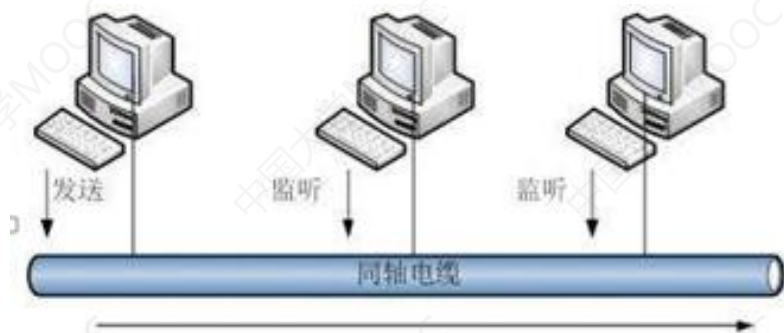
2. 窃听攻击后果

- 一是破坏信息的保密性。
- 二是嗅探攻击是实现数据流分析攻击的前提。
- 三是实施重放攻击。

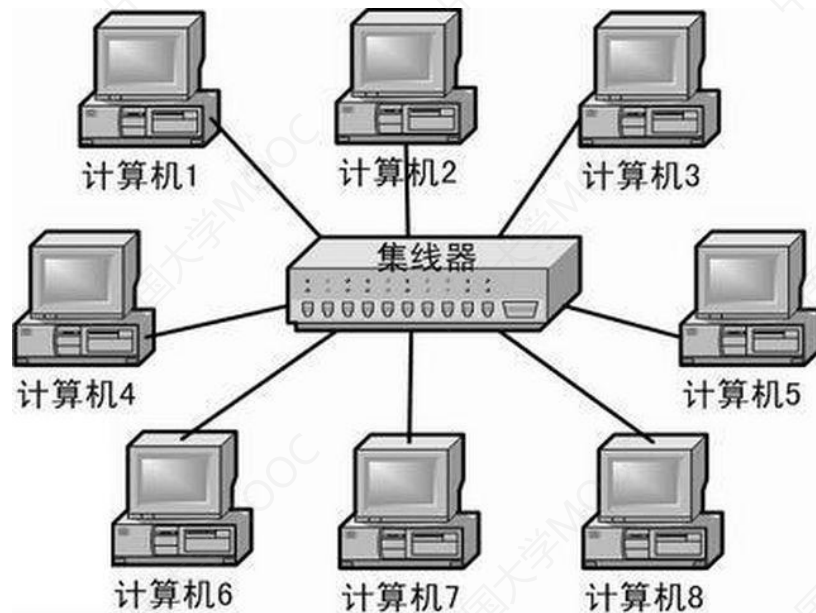


2.2.1 窃听攻击的原理及后果

从以太网的发展看窃听技术的发展



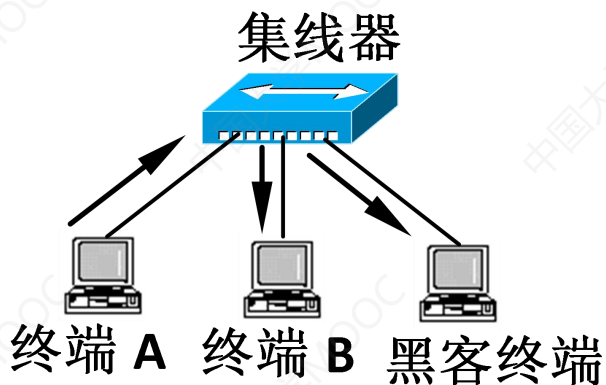
总线式



CSMA/CD:载波侦听多点访问/冲突检测

2.2.2 集线器工作原理和窃听攻击

1. 集线器工作原理



➡ : 终端 A 至终端 B 的 MAC 帧

由于集线器接收到MAC帧后，通过除接收端口以外的所有其他端口输出该MAC帧，因此，在有黑客终端接入集线器的情况下，集线器完成终端A至终端B的MAC帧传输过程的同时，将该MAC帧传输给黑客终端。

实践要求1:

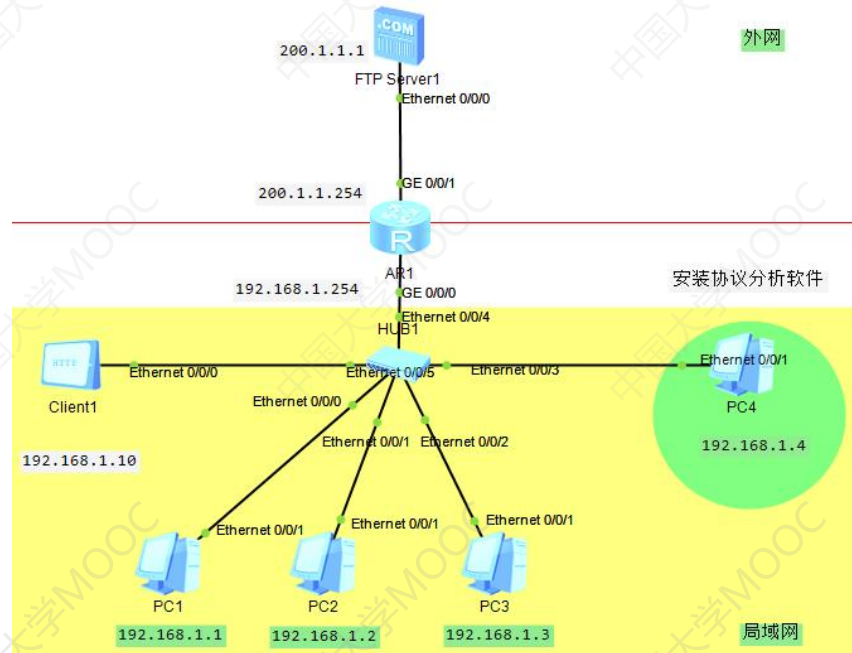
- 用PT搭建网络拓扑，进行集线器工作原理的验证
- 了解广播式发送数据包的不足
- 思考如何防御通过集线器实现的窃听攻击

2.2.2 集线器工作原理和窃听攻击

1. 集线器工作原理

实践要求2：验证集线器网络环境下实现窃听攻击

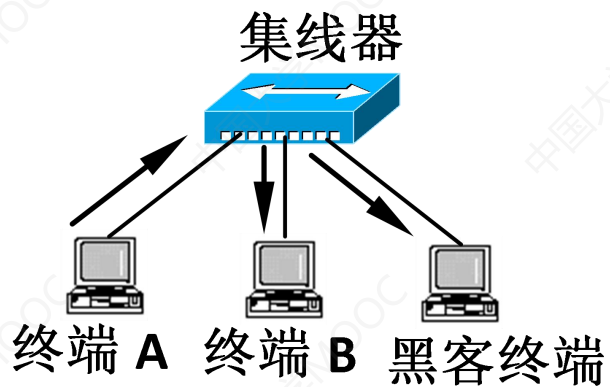
➤ 用华为eNSP搭建网络拓扑，进行集线器网络环境下实现窃听攻击的验证



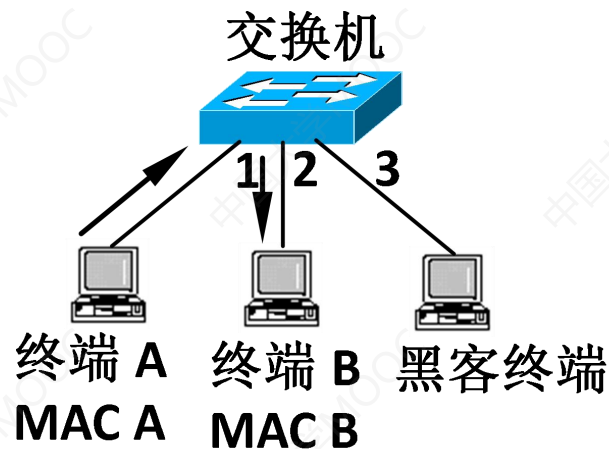
No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.1.10	200.1.1.1	TCP	58	2051 → 21 [SYN] Seq=0 Win=8192 Len=0 MSS=1460
2	0.031000	200.1.1.1	192.168.1.10	TCP	58	21 → 2051 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460
3	0.031000	192.168.1.10	200.1.1.1	TCP	54	2051 → 21 [ACK] Seq=1 Ack=1 Win=8192 Len=0
4	0.031000	200.1.1.1	192.168.1.10	FTP	87	Response: 220 FtpServerTry FtpD for free
5	0.031000	192.168.1.10	200.1.1.1	FTP	66	Request: USER admin
6	0.046000	200.1.1.1	192.168.1.10	FTP	89	Response: 331 Password required for admin .
7	0.046000	192.168.1.10	200.1.1.1	FTP	67	Request: PASS 123456
8	0.046000	200.1.1.1	192.168.1.10	FTP	90	Response: 230 User admin logged in , proceed
9	0.046000	192.168.1.10	200.1.1.1	FTP	59	Request: PWD
10	0.062000	200.1.1.1	192.168.1.10	FTP	84	Response: 257 "/" is current directory
11	0.062000	192.168.1.10	200.1.1.1	FTP	62	Request: TYPE A
12	0.078000	200.1.1.1	192.168.1.10	FTP	78	Response: 200 Type set to ASCII.
13	0.078000	192.168.1.10	200.1.1.1	FTP	60	Request: PASV
14	0.078000	200.1.1.1	192.168.1.10	FTP	97	Response: 227 Entering Passive Mode (200,1,1,1,8,2)
15	0.078000	192.168.1.10	200.1.1.1	FTP	61	Request: LIST

2.2.2 集线器工作原理和窃听攻击

从共享式以太网到交换式以太网是一次革新



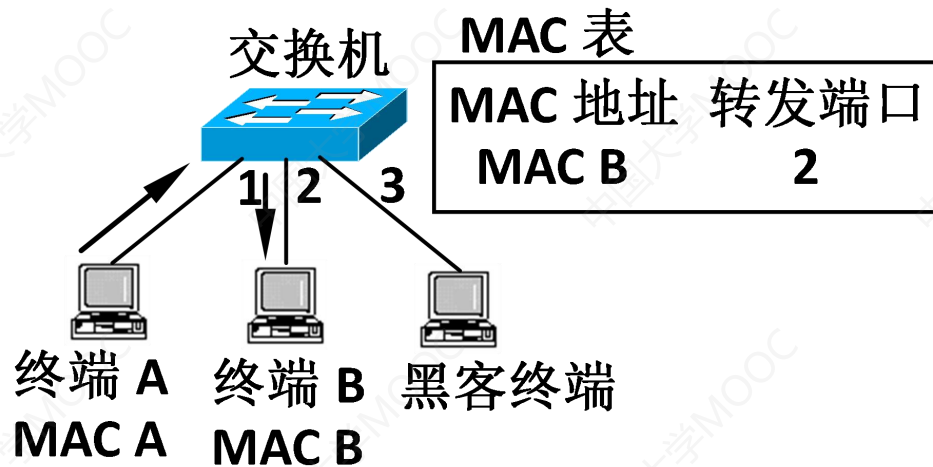
→ : 终端 A 至终端 B 的 MAC 帧



→ : 终端 A 至终端 B 的 MAC 帧

2.2.3 交换机工作原理和MAC表溢出攻击及防御

1. 交换机工作原理



由于交换机转发表中存在终端B对应的转发项，该转发项表明MAC地址为MAC B的终端连接在端口2上。因此，当终端A发送的源MAC地址为MAC A、目的MAC地址为MAC B的MAC帧到达交换机时，交换机只从端口2输出该MAC帧。这种情况下，黑客终端即使与终端B连接在同一个交换机上，也无法接收终端A传输给终端B的MAC帧。

实践要求1:

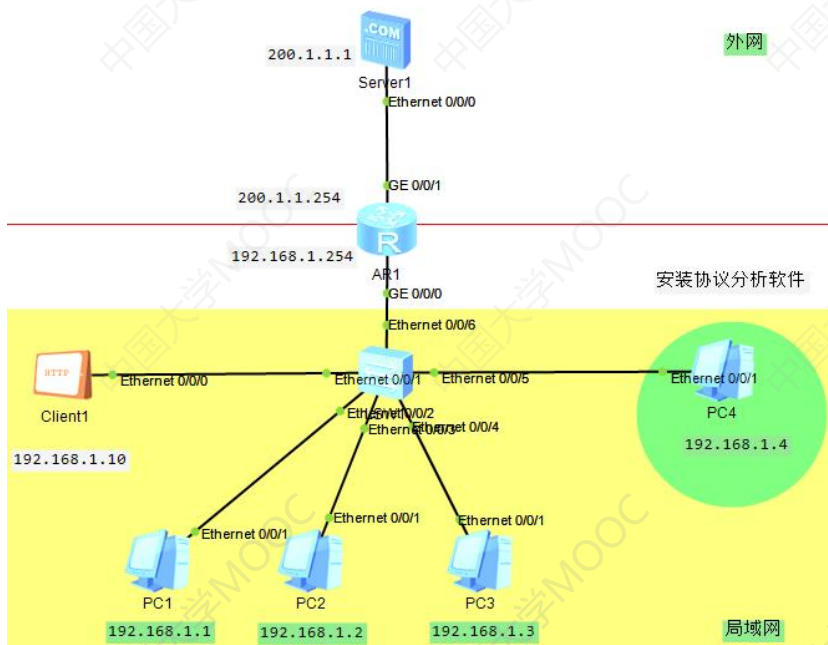
➤用PT搭建网络拓扑，进行交换机工作原理的验证

2.2.3 交换机工作原理和MAC表溢出攻击及防御

1. 交换机工作原理

实践要求2：验证交换机网络环境下是否还能正常实现窃听攻击

➤ 用华为eNSP搭建网络拓扑，进行交换机网络环境下是否还能正常实现窃听攻击验证



思考：

➤ 如何在交换机环境下实现窃听攻击？

2.2.3 交换机工作原理和MAC表溢出攻击及防御

2. 交换MAC溢出攻击

正常的MAC地址学习流程，**被黑客利用**，变成交换机的一个漏洞

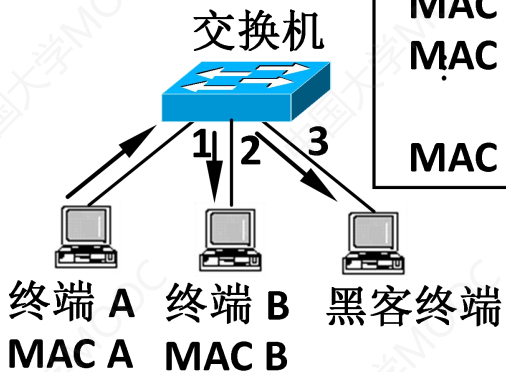
通过耗尽交换机转发表的存储空间，使得交换机无法根据收到的MAC帧在转发表中添加新的转发项的攻击行为。

2.2.3 交换机工作原理和MAC表溢出攻击及防御

2. 交换MAC溢出攻击

MAC 表

MAC 地址	转发端口
MAC 1	3
MAC 2	3
MAC n	3



通过耗尽交换机转发表的存储空间，使得交换机无法根据收到的MAC帧在转发表中添加新的转发项的攻击行为。

1. 黑客终端不断发送源MAC地址变化的MAC帧，如发送一系列源MAC地址分别为MAC 1、MAC 2、...、MAC n的MAC帧，使得交换机转发表中添加MAC地址分别为MAC 1、MAC 2、...、MAC n的转发项，这些转发项耗尽交换机转发表的存储空间，
2. 当交换机接收到终端B发送的源MAC地址为MAC B的MAC帧时，由于转发表的存储空间已经耗尽，因此，无法添加新的MAC地址为MAC B的转发项，
3. 导致交换机以广播方式完成MAC帧终端A至终端B传输过程。

思考：

- 除了通过MAC表溢出实现窃听，还有没其他方式攻击交换机实现窃听
- 如何防御通过交换机实现的窃听攻击

2.2.3 交换机工作原理和MAC表溢出攻击及防御

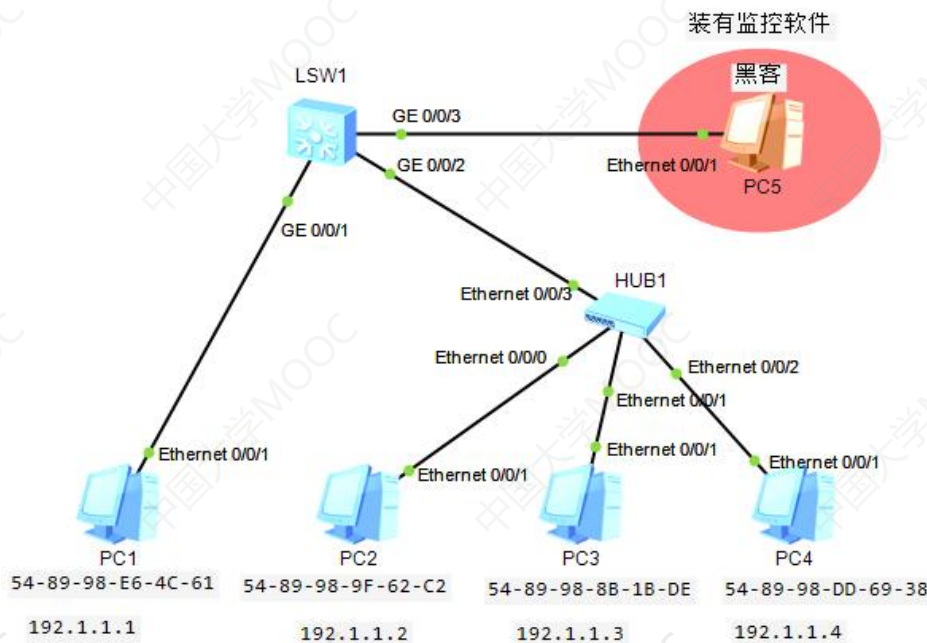
2. 交换MAC溢出攻击

实践要求:

➤用华为eNSP搭建网络拓扑，验证交换机溢出攻击

关键命令和步骤:

1. PC1 分别ping PC2 PC3 PC4
2. 查看交换机LSW1的MAC地址表，命令：
<huawei>**display mac-address** 显示交换机MAC表中的转发项
3. 清空交换机的MAC地址表，并**设定端口GE0/0/2最多允许学到2个地址**，交换机LSW1命令行接口配置过程
<Huawei>system-view
[Huawei]undo info-center enable
[Huawei]undo mac-address all
[Huawei]interface gigabitethernet0/0/2
[Huawei-GigabitEthernet0/0/2]mac-limit maximum 2
[Huawei-GigabitEthernet0/0/2]quit
4. 再次用PC1 分别ping PC2 PC3 PC4
5. 再次查看交换机LSW1的MAC地址表：
<huawei>**display mac-address**
6. 在ge0/0/3端口启动wireshark抓包，**pc1 ping PC4的包会被广播发送，并在ge0/0/3端被抓到**
7. 其他命令：
display mac-limit 查看已经配置的针对MAC地址学习功能的限制



2.2.3 交换机工作原理和MAC表溢出攻击及防御

2. 交换MAC端口镜像攻击

思考:

- 除了通过MAC表溢出实现窃听，还有没其他方式攻击交换机实现窃听

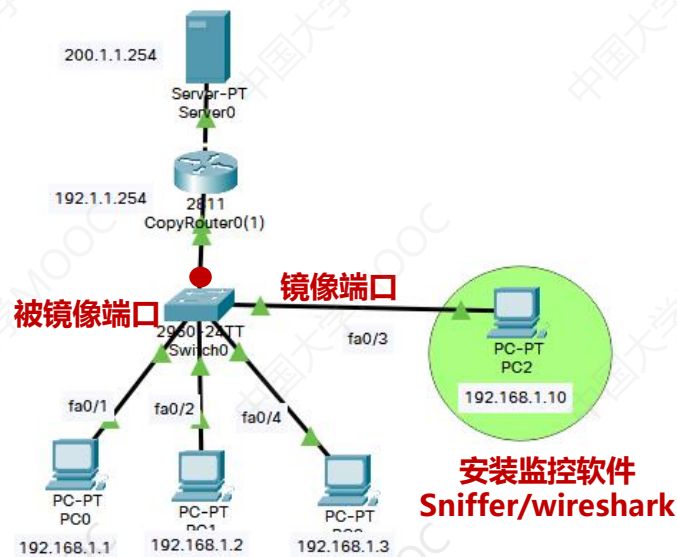
➤ 方法: 利用交换机端口镜像功能进行攻击

实践要求:

- 用PT搭建网络拓扑，验证交换机端口镜像功能，并进行交换机防窃听攻击的实验

关键命令:

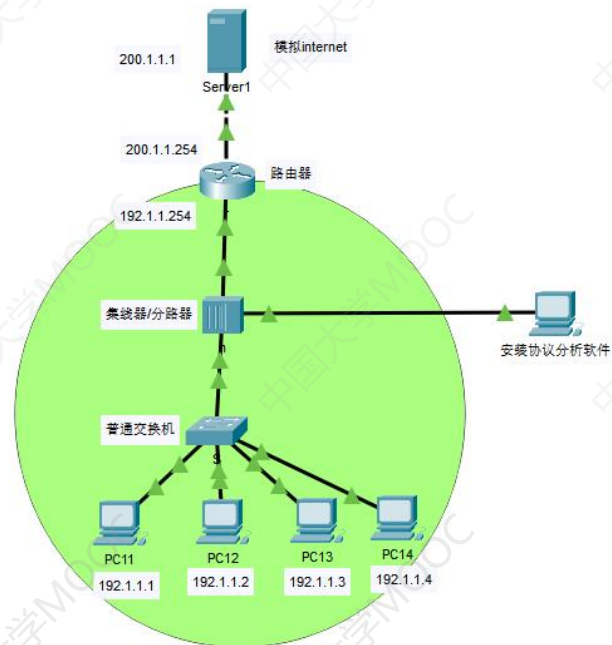
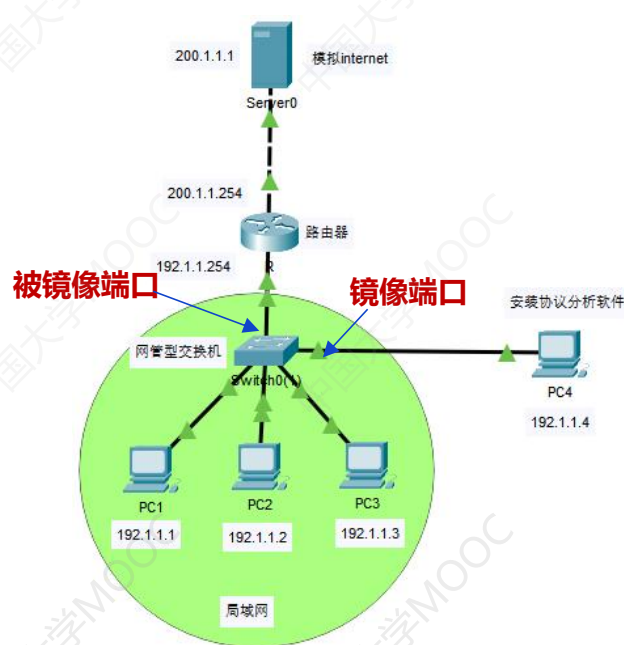
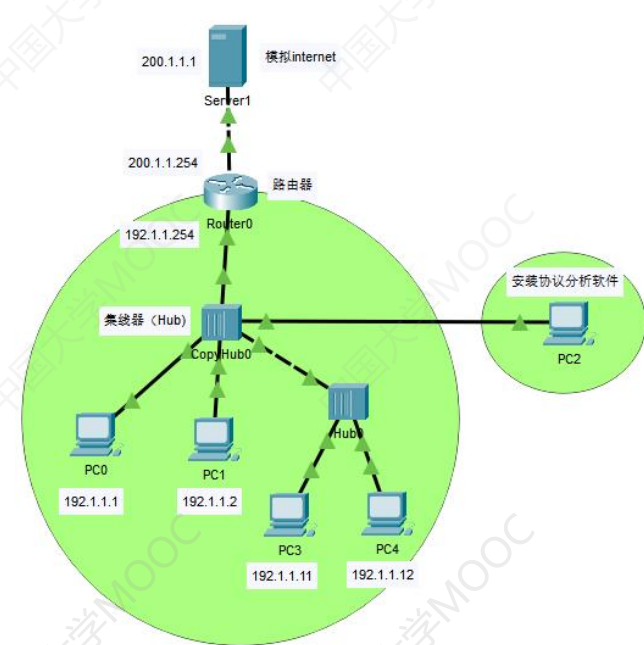
```
Switch(config)#monitor session 1 source interface fa0/1  
Switch(config)#monitor session 1 destination interface fa0/3
```



窃听模式

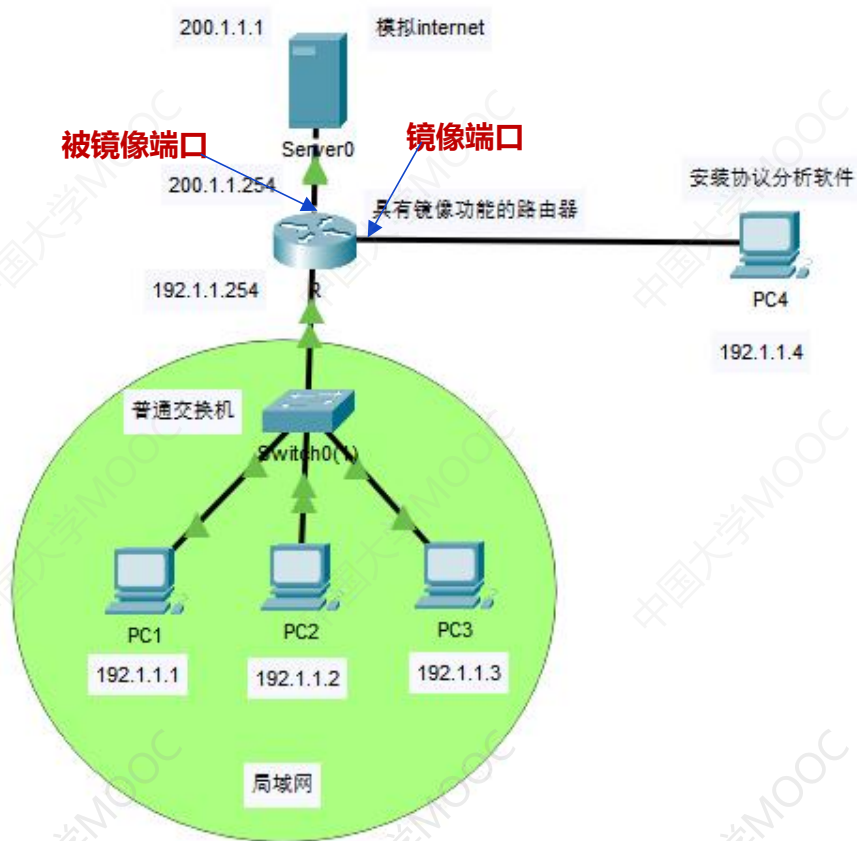
□ 监听模式

- (1) 通过共享式网络
- (2) 通过拥有镜像备份功能的交换式网络
- (3) 通过拥有镜像功能的相互交换式网络



窃听模式总结

□ 监听模式



2.2.3 交换机工作原理和MAC表溢出攻击及防御

3. 窃听攻击的防御

- 对于通过集线器实现的窃听攻击，需要有**防止黑客终端接入集线器的措施**。
- 对于通过交换机实现的窃听攻击，一是需要有**防止黑客终端接入交换机的措施**，二是交换机**需要具有防御MAC表溢出攻击的机制**。
- 对于无线通信过程，窃听攻击是无法避免的，这种情况下，需要对传输的信息进行**加密**，使得黑客终端即使窃听到信息，也因为无法对信息解密而无法破坏信息的保密性。

2.2.3 交换机工作原理和MAC表溢出攻击及防御

3. 窃听攻击的防御

□MAC表溢出的直接**原因**：交换机接收到太多源MAC地址不同的MAC帧。

□解决**思路**：限制每个端口允许接收的源MAC地址不同的MAC帧的数量

实践要求：

➤用PT搭建网络拓扑，进行交换机防窃听攻击的实验

访问控制列表实验（静态配置）

安全端口实验（动态访问控制列表）

具体措施：在交换机端口应用安全策略

2.2.3 交换机工作原理和MAC表溢出攻击及防御

3. 窃听攻击的防御

访问控制列表实验（静态配置） P66

```
Switch(config)#interface FastEthernet0/1
Switch(config-if)#switch mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security mac-address 00e0.a3bd.703a
Switch(config-if)#switchport port-security violation shutdown
```

安全端口实验（动态访问控制列表） P69

```
Switch(config)#interface FastEthernet0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 2
Switch(config-if)#switchport port-security mac-address sticky
Switch(config-if)#switchport port-security violation protect
```

具体措施：在交换机端口应用安全策略

本质：限定端口映射的MAC数量

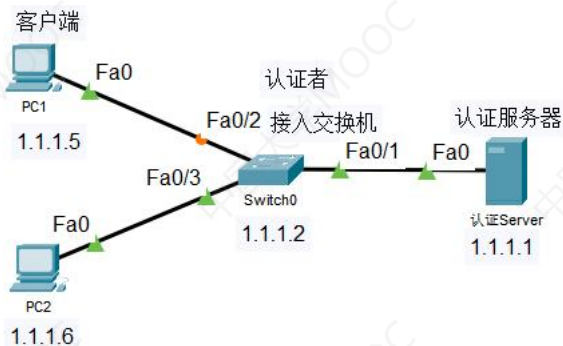
违反策略时采取的行动：

- ❑ **Protect:**只丢弃该MAC帧
- ❑ **Restrict:**丢弃MAC帧，计数丢弃的MAC帧数量，并在日志中记录该事件
- ❑ **shutdown:** 丢弃该mac帧，计数丢弃的mac帧数量，在日志中记录该事件，并关闭该交换机端口

2.2.3 交换机工作原理和MAC表溢出攻击及防御

3. 窃听攻击的防御

补充: 采用802.1X端口认证



```
Switch>enable
Switch#configure terminal
Switch(config)#interface vlan 1
Switch(config-if)#ip address 1.1.1.2 255.0.0.0
Switch(config-if)#exit
Switch(config)#dot1x system-auth-control //启用DOT1X认证
Switch(config)#aaa new-model //配置认证服务器
Switch(config)#aaa authentication dot1x default group radius
Switch(config)#radius-server host 1.1.1.1 auth-port 1645 key cisco
Switch(config)#interface fa0/2 //接口级别的DOT1X设置
Switch(config-if)#switchport mode access
Switch(config-if)#authentication port-control auto
Switch(config-if)#dot1x pae authenticator
```

801.1x协议：控制用户的网络访问权限，防止身份不明或未经授权的用户传输和接收数据。

802.1X基于端口的认证过程：

- 第一步：主机A先向交换机提出请求，我要加入；
- 第二步：交换机问主机，用户名密码多少；
- 第三步：主机A提交用户名密码给交换机；
- 第四步：交换机拿着用户名密码去找AAA服务器询问，请验证是否为合法用户；
- 第五步：AAA验证之后，告诉交换机，是合法用户；
- 第六步：交换机这时才打开交换机接口；
- 第七步：主机A的正常流量可以进入，加入完成。

- 接入设备对连接到链路的客户端进行认证。在认证通过之前，IEEE802.1x只允许**EAPOL**报文通过端口；
- 接入设备与认证服务器之间运行**EAP**协议，接入设备将EAP帧封装到**RADIUS**报文中，并通过网络发送给认证服务器。
- 当接入设备接收到认证服务器返回的认证响应后，再从RADIUS报文中提取出EAP信息并封装成EAP帧发送给客户端。

有问题及时反馈，加强沟通交流！

补充知识：网络监控软件——网路岗软件

1. 网路岗的基本功能

- “网路岗”由深圳德尔软件公司开发。是国内广泛使用且专业的**网络监控软件及局域网监控产品**。只需要通过一台电脑即可监控整个网络的网络活动，是政府机构、企事业单位和校园网吧上网的管理软件之一。
- 网路岗软件**通过旁路/透明网桥/虚拟网桥模式，对网络数据流进行采集、分析和识别**，实时监视网络系统的运行状态，记录网络事件、发现安全隐患，并对网络活动的相关信息存储、分析和协议还原。该产品可监视企业内部员工是否将公司机密资料通过因特网外传到竞争对手的手中。
- 网路岗软件可以监控的内容包括：监控邮件内容和附件（包括Web邮件监控）、监控聊天内容、监控上网网站、监控FTP外传文件、监控Telnet命令、监控上网流量；IP过滤、端口过滤、网页过滤、封堵聊天游戏；限制外发资料邮件大小；限制网络流量；IP-MAC绑定；截取屏幕等。

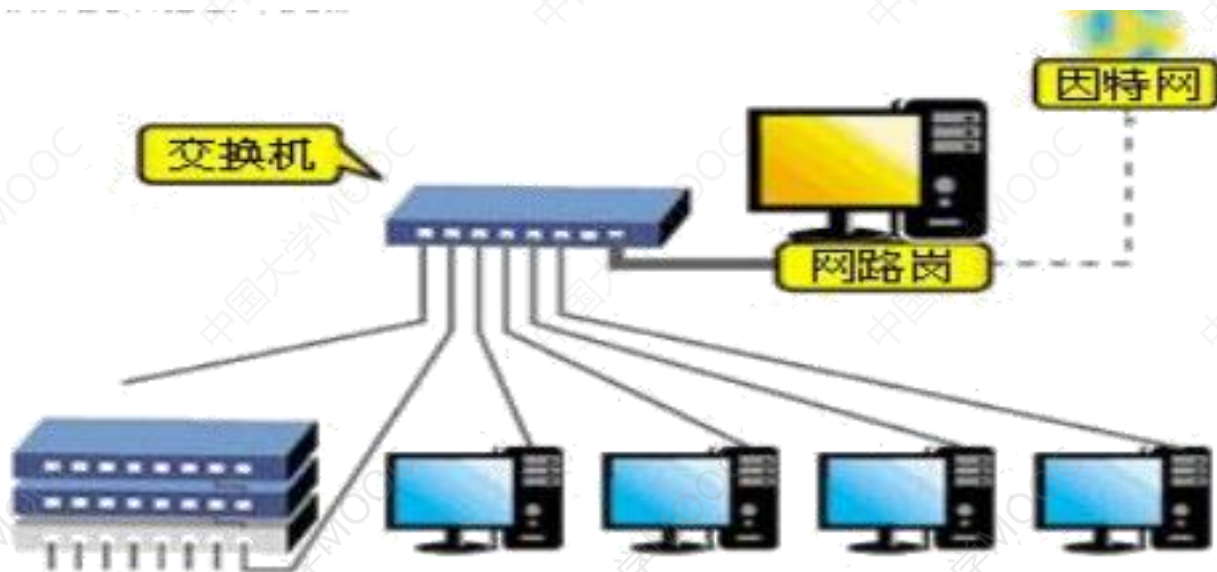
2. 网路岗对上网的监控能做到什么程度？

- (1) 让某人只能在规定时间上网，且只能上指定的网站。
- (2) 让某人只能在哪个网站上收发邮件，只能收发哪类的邮箱。
- (3) 谁什么时候通过什么软件发送了什么邮件或通过哪个网站发了什么软件，邮件的内容和附件是什么，以及附件在发送者电脑的具体位置。
- (4) 规定某人只能发送多大的邮件。
- (5) 规定某些人只能发送到哪些目标邮箱。
- (6) 轻松抓取指定人的电脑屏幕。
- (7) 所有机器在一天内各时间段的上网流量。
- (8) 某台机器哪些外部端口不能用，或只能通过哪些端口和外界联系。

补充知识：网络监控软件——网路岗软件

3. 网路岗的安装方式？

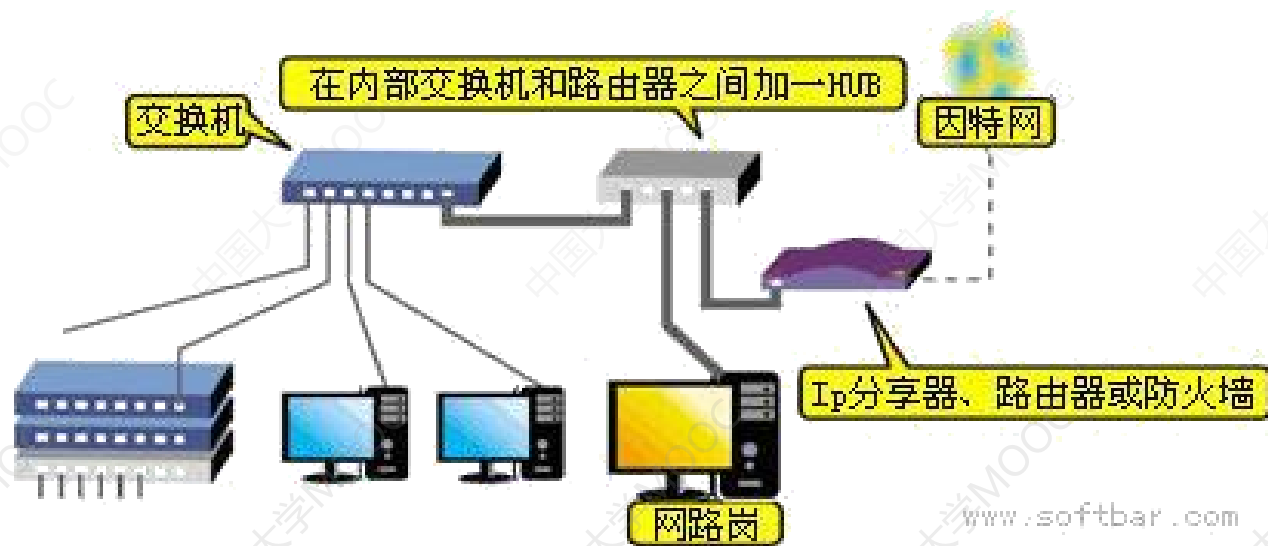
- 网路岗安装在代理服务器上，绑定内网的网卡，通过安装“代理服务器软件”或“网路岗NAT”，实现所有机器共享一个出口上网。
- 安装方法：将网路岗安装在代理服务器上，绑定内网的网卡，网路岗设置为“非旁路监控模式”，重新启动计算机。



补充知识：网络监控软件——网路岗软件

3. 网路岗的安装方式？

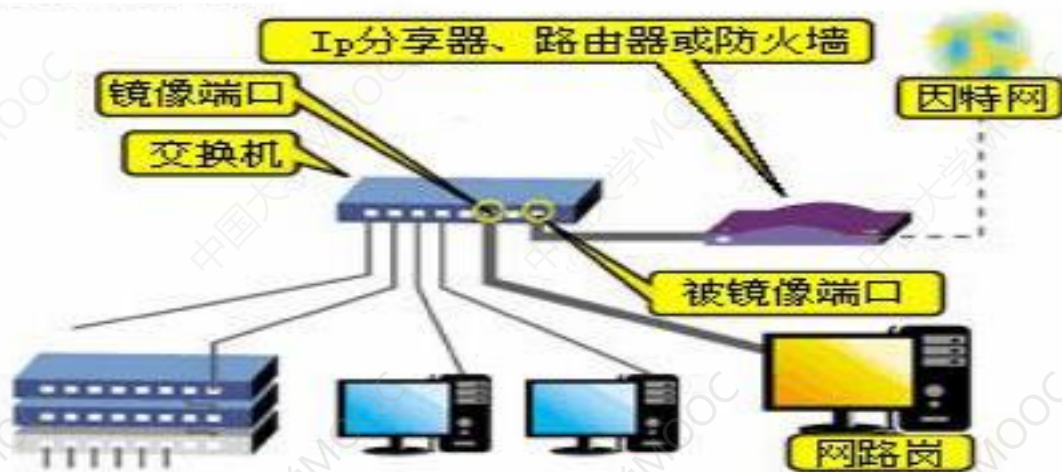
- 网路岗安装在HUB的一个端口上，通过“IP分享器、路由器或防火墙”实现整个网络共享一个出口上网，且内部交换机均不具备设置镜像端口的功能。
- 安装方法：在内部交换机和路由器之间加一个共享式HUB，再将安装“网路岗”的机器网线也接到HUB上，网路岗设置为“旁路监控”模式。



补充知识：网络监控软件——网路岗软件

3. 网路岗的安装方式？

- 网路岗安装在交换机的镜像端口上，通过“IP分享器、路由器或防火墙”实现整个网络共享一个出口上网，且内部主交换机具备设置镜像端口的功能。
- 安装方法：在内部主交换机上设置端口镜像，将接路由器的网线设置为“被镜像端口”，将接“网路岗”的网线设置为“镜像端口”。网路岗设置为“旁路监控”模式。

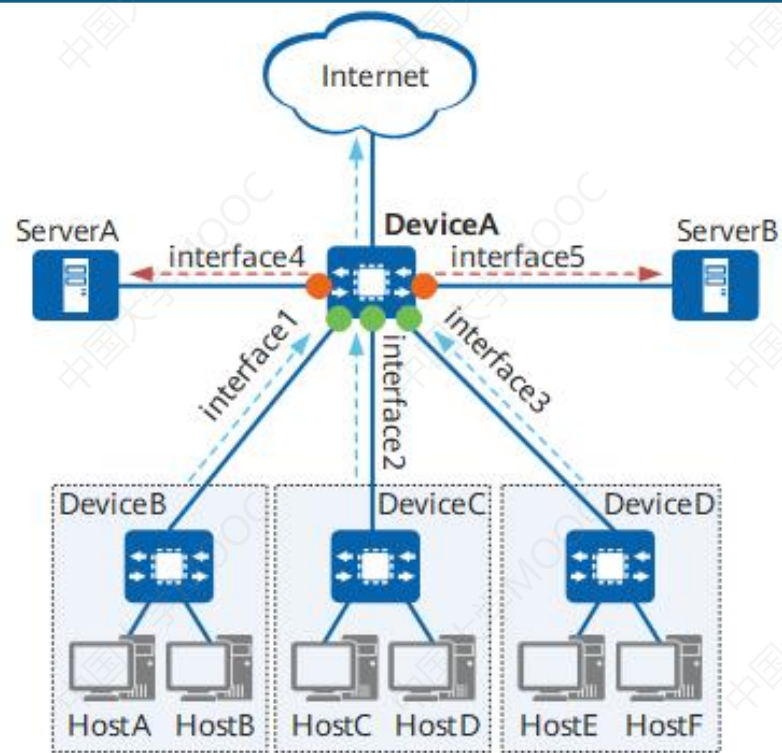


补充知识：网络监控软件——网路岗软件

3. 网路岗的安装方式？

- 网桥模式（非旁路模式）：网路岗安装在网桥上，在一台双网卡计算机上建立网络桥，将该网络桥放在internet出口处。
- 安装方法：直接将网路岗安装在启动网络桥的机器上，网路岗绑定在内网的网卡上，同时给网络桥配置IP使其能访问内部网其他其他机器。网路岗设置为“非旁路监控模式”，重新启动计算机。





● 镜像端口

● 观察端口

→ 原始报文

→ 镜像报文

CSDN @ 11-32

11月1日是什么日子？

<https://baijiahao.baidu.com/s?id=1748165409329873811&wfr=spider&for=pc>



中华人民共和国 反间谍法

2014年11月1日

国家安全 人人有责
反奸防谍 你我携手



我们都是
国家安全的守护人

《公民举报危害国家安全行为奖励办法》规定对举报有功人员依法予以奖励



中华人民共和国反间谍法
中华人民共和国反间谍法实施细则

中国法制出版社

哪些人员是间谍策反的重点目标？

据国家安全机关统计：



留学生



高校师生



军事发烧友



军工企业
国防科研单位人员



年轻网友等

容易被境外间谍机构策反，可能会被利用

国外某情报机构发展间谍的“MICE 法则”

M

金钱：见钱眼开，追求生活奢侈享受者

I

意识形态：迷恋西方思想，诋毁本国体制者

C

个人表现：个人成就动机极其强烈，渴望被万众瞩目者

E

道德：道德品质低下，生活作风不检点者

国外的一些间谍或情报人员



从事这些间谍活动的情报人员都将受到中国法律的处罚

留心！间谍常常这样做！

《今日说法》 20231022 迷失境外

国家机关如何反间谍？

对可疑人员

- 可依法行使侦查、拘留、预审
- 因工作需要可查验组织和个人的电子通信工具等设备设施

依法执行任务，
经出示相应证件

- 可向有关组织和人员调查、询问相关情况
- 有权查验中国公民或境外人员的身份证明

经批准
出示相应证件

- 可进入限制进入的有关场所、单位；查看或调阅相关档案资料等